

# W3WI\_SE411 - Forschungsseminar Informatik / Advanced Practical IT Security



**Dozent:** [Prof. Dr. Michael Eichberg](#)  
**Kontakt:** [michael.eichberg@dhbw-mannheim.de](mailto:michael.eichberg@dhbw-mannheim.de) , Raum 149B  
**Unterlagen:** Moodle  
**Version:** 24SEA - 2026-08-27

# Teaser

In dieser Veranstaltung werden wir uns mit den Grundlagen praktischer Angriffe und Verteidigungsmaßnahmen im Bereich IT Security auseinandersetzen. Wir werden uns der Frage widmen wie, wann und in welcher Form man - auf den ersten Blick abgesicherte Systeme/geschützte Daten - einerseits angreifen (🚩 *to exploit*) kann und wie man die Sicherheit weiter erhöhen kann.

Wir werden uns in diesem und dem nächsten Semester ausgewählten Themen widmen, die von der Sicherheit von Passwörtern und Angriffen auf selbige bis hin zu der Sicherheit von Netzwerken und Webanwendungen reichen.

Wir werden uns somit auf praktische Aspekte der IT Sicherheit fokussieren. Theoretische Grundlagen sind nur in so weit relevant, dass sie in der Praxis eine Relevanz haben.

## ※ Hinweis

Für diese Veranstaltung sind Grundkenntnisse in Linux/Unix/macOS hilfreich aber nicht notwendig. Notwendig ist aber Interesse an tiefer gehenden technischen Details.

Es wird empfohlen sich eine virtuelle Maschine (z. B. mit VirtualBox oder UTM) aufzusetzen, auf der Sie Linux (ganz insbesondere z. B. Kali Linux) oder ggf. Mac OS installieren. Auf eigene Gefahr hin können Sie auch WSL2 unter Windows verwenden. Mac User können viele der Tools direkt installieren oder über Homebrew bzw. MacPorts beziehen.

Eine installation in einer VM ist aber immer empfohlen.

## Grober Ablauf

- 1. Semester: 6 Termine; (50% der Endnote - d. h. 60 von 120 Punkten)
- 2. Semester: X Termine (50% der Endnote - d. h. 60 von 120 Punkten)

# 1. Erstes Semester: Passwortwiederherstellung und Reverse-Engineering

## Ablauf - 1. Semester

- 28. August:** *Einführung in Passwortwiederherstellung*  
**4. September:** Begleitung bei der Bearbeitung von Übungen  
**7. September:** **Bewertetes Lab (max. 30 Punkte)** zum Thema Passwortwiederherstellung

▲ Achtung!

Sollten Sie an diesem Tag verhindert sein, dann ist ein offizieller Prüfungsrücktritt erforderlich!

- 11. September:** *Einführung in Reverse Engineering*  
**18. September:** Begleitete Übung zum Thema Reverse Engineering  
**12. Oktober:** **Bewertetes Lab (max. 30 Punkte)** zum Thema Reverse Engineering

▲ Achtung!

Sollten Sie an diesem Tag verhindert sein, dann ist ein offizieller Prüfungsrücktritt erforderlich!

# Inhalte

## ※ Hinweis

Diese Veranstaltung ist ergänzend zur Veranstaltung SE III IT-Sicherheit zu sehen. D. h. Inhalte, die dort vermittelt werden, werden hier nicht noch einmal behandelt, sind aber potentiell relevant.

## Notenzusammenstellung - 1. Semester - Passwortwiederherstellung

| <b>Leistungsnachweis</b>                             | <b>Notenanteil</b> |
|------------------------------------------------------|--------------------|
| Fachpräsentation (10 Minuten pro Person)             | 15%                |
| Lösungen der Aufgaben bzg. Passwortwiederherstellung | 15%                |
| Lösungen der Aufgaben bzgl. Reverse Engineering      | 15%                |
| Lösungspräsentationen (5 Minuten pro Person)         | 5%                 |

## 2. Zweites Semester: Pentesting von Webanwendungen



## Ablauf - 2. Semester (voraussichtlich)

1. Einführung in Pentesting
2. Studentische **Präsentationen** zur Vertiefung bzw. Betrachtung wichtiger Aspekte.
3. Aufgaben für die entsprechende Fragestellung.
4. Prüfungsgespräch zu Ihren Ergebnissen

# Ablauf

:::::{story}

{.incremental-list}

X.Y.2027

- : - Ausgabe der Themen zur Bearbeitung
- Kurze Einführung in das Thema Pentesting

X.Y.2027

- : - Bearbeitung der Themen mit dem Ziel „Hands-on“
- Ich stehe für Rückfragen *\*online\** (<<https://bbb.dhbw.de/rooms/eic-uue-f52-6xb/join>>) zur Verfi

X.Y.2027

- : - Halten der Präsentationen (Doppeltermin)
- Thema 1 bis 12

X.Y.2027

- : - Halten der Präsentationen
- Thema 13 bis 18

X.Y.2027 - Online

- : - Ausgabe der Pentesting-Aufgabe

::::{compound}

:class: incremental

## X.Y.2027 (Prüfungsgespräche)

- Gruppenindividuelle Prüfungsgespräche (8 Gruppen)

# Vortragsthemen - Grundlagen

**\*\*Dauer pro Person: 15 Minuten\*\***

:::{story}

{.list-with-explanations .incremental-list}

- [1 Person] Grenzen der Multi-Faktor-Authentifizierung  
(MFA fatigue, [Token Theft])(<https://www.heise.de/en/news/Microsoft-Authenticator-Critical-vulnerat>)
- [1 Person] [Shodan](<https://www.shodan.io>) and OSINT im Pentesting
- [1 Person] Server-Side Request Forgery ([Portswigger - SSRF])(<https://portswigger.net/web-security/>)  
(Ggf. inkl. Demonstration und Erklärung wie man sich schützt.)
- [2 Personen] [MITRE ATT&CK](<https://attack.mitre.org>)

(Knowledge base of adversary tactics and techniques based on real-world observations.)

1. Person - allgemeine Einführung

2. Person - Darstellung ausgewählter Themen

(Bitte darauf achten, dass es mit den OWASP Vorträgen zu keinen relevanten Überschneidungen kommt.)

- [1 Person] [OWASP Web Security Testing Guide](<https://owasp.org/www-project-web-security-testing-g>)
- [1 Person] [OWASP Mobile Application Security](<https://owasp.org/www-project-mobile-app-security/>)
- [1 Person] Copy Fail (<<https://copy.fail>>) (case study)

Als Case-study aufarbeiten und auch die Entstehungsgeschichte erklären. Bitte auch in Relation zu

- [1 Person] [Scapy](<https://scapy.net/>)

(Interactive packet manipulation library)

Eine Demo ist sehr wünschenswert.

- [1 Person] [OpenVAS - Community Edition](<https://greenbone.github.io/docs/latest/background.html#e>)  
(Vulnerability Testing)

\*Achtung: bei der Community Edition handelt es sich wohl um ein „rohes Produkt“.\*

- [2 Personen] [OWASP Top Ten 2025](<https://owasp.org/Top10/2025/>) (z. B. 1. Person Lücke 1-5; 2. Person Lücke 6-10)  
Jeweils mit konkreten Beispielen in etablierten Sprachen/Frameworks.
- [2 Personen] [OWASP Top Ten for LLM Applications](<https://genai.owasp.org/resource/owasp-top-10-for-llm-applications/>)
- [1 Person] Wireshark für Pentester

Fokus auf: typische Filter, Credentials finden, verdächtige Muster

- [1 Person] [Gobuster](<https://github.com/OJ/gobuster>)

(A directory/file, DNS and virtual host brute-forcing tool)

:::

% Vorträge auf Vorrat :

- % - **\*\*Fingerprinting von Webanwendungen\*\***
- % - Frameworks, Server, CMS erkennen
- % - Warum das für Angriffe relevant ist
- % - **\*\*Schwache Netzwerkdienste & Legacy-Protokolle\*\***
- % - FTP, Telnet, SMBv1
- % - Warum sie heute noch existieren
- % - **\*\*Kali Linux - Überblick über typische Pentest-Tools\*\***
- % - Tool-Kategorien statt Tool-Details
- % - Warum Kali Standard ist

# Vortragsthemen - Angewandt

**\*\*Dauer pro Person: 15 Minuten\*\***

::::{story}

:::{attention}

Niemand, der eines der folgenden Themen bearbeitet, darf mit jemand anderem aus dieser Gruppe bei de

:::

{.list-with-explanations .incremental-list}

- [1 Person] [Nmap (und ncat)](<https://nmap.org/>)

(Network discovery and security auditing.)

- [2 Personen] [Zed Attack Proxy (ZAP)](<https://www.zaproxy.org/>)

(Web App Scanner)

1. Einführung (inkl. Marketplace)

2. Live Demo basierend auf einer Webanwendung (bitte erst in die Anwendung und die Lücken einführe

- [2 Personen] [Burp Suite](<https://portswigger.net/burp/communitydownload>)

(Penetration testing toolkit.)

1. Einführung (inkl. Marketplace)

2. Live Demo basierend auf einer Webanwendung (bitte erst in die Anwendung und die Lücken einführe

- [2 Personen] [Metasploit (Open Source)](<https://www.metasploit.com/>)

(Penetration testing framework.)

1. Einführung in Metasploit - d. h. Architektur und Aufbau von Metasploit
  2. Live Demo (bitte erst in das Szenario einführen)
- [1 Person] [Nikto](https://cirt.net/nikto/)
- (Open-source web server scanner checking for dangerous or interesting files and programs, identify
- ::::

#### # Themenverteilung

:::{scrollable}

```{csv-table}

:class: sticky-header

:header: Nr., Thema, #Stud., 1. Student, 2. Student

:width: 100%

:widths: 1,6,2,10,10

|     |                              |   |         |          |
|-----|------------------------------|---|---------|----------|
| 1.  | MFA                          | 1 | Wrede   |          |
| 2.  | OSINT                        | 1 | Weber   |          |
| 3.  | SSRF                         | 1 | Clauss  |          |
| 4.  | ATT&CK                       | 2 | Teschke | Tikce    |
| 5.  | OWASP - WSTG                 | 1 | Stammer |          |
| 6.  | OWASP - MAS                  | 1 | Wieder  |          |
| 7.  | Gobuster                     | 1 | Müller  |          |
| 8.  | Scapy                        | 1 | Saado   |          |
| 9.  | OpenVAS                      | 1 | Singh   |          |
| 10. | OWASP Top Ten                | 2 | Pjano   | Korten   |
| 11. | "OWASP Top Ten for LLM Apps" | 2 | Erhard  | Bäck     |
| 12. | Wireshark                    | 1 | Jun     |          |
| 13. | Copy Fail                    | 1 | Plett   |          |
| 14. | Nmap                         | 1 | Molter  |          |
| 15. | ZAP                          | 2 | Priemer | Meli     |
| 16. | Burp                         | 2 | Stahl   | Zweigert |
| 17. | Metasploit                   | 2 | Meinel  | Sönmez   |
| 18. | Nikto                        | 1 | Kling   |          |

:::

#### # Bewertungskriterien

:::~::~{deck}

:::~::~{card}

:::{rubric} Für die Präsentation Ihres Fachvortrags  
 :::

- [Hinweise für Präsentationen](../allg-vortraege/folien.de.md.html)

- Notenanteil: 25% von der Gesamtnote - d.h. 30 Punkte:

{.list-with-explanations}

- 29 Punkte für den Vortrag

Der Vortrag muss am Tag der Präsentation bis spätestens 7:00 Uhr hochgeladen sein.

Für die Teile, die sie demonstrieren, laden Sie bitte eine ausreichende Anzahl an Screenshots (i

- 1 Punkt für das Ausfüllen, Gegenzeichnen und zeitgerechte Hochladen der [Checkliste](../allg-vor

Bei Gruppenarbeit hat dies jeder Studierende eigenständig zu machen; es erfolgt keine Abgabe der

::::

::::::{card}

:::{rubric} Für die mündliche Prüfung (X.Y.2027 - Raum 261C)

:::

::::::{deck}

::::{card}

- Anzahl und Art der gefundenen Schwachstellen

Fertigen Sie ein Dokument (.md, .pdf) an, dass Sie vorher (siehe Moodle) hochladen und in dem Sie

:::{attention}

Eine detaillierte Dokumentation ist nicht erforderlich, da es sich im wesentlichen, um ein Prüfungs  
Es geht hier ausschließlich um eine knappe Auflistung der Lücken! Eine Beschreibung der Lücken ode

{warning}`Der Einsatz von KI zur Erstellung/Verbesserung der Liste ist strikt untersagt.`

:::

**\*\*Wir werden diese Liste als Start für das Prüfungsgespräch verwenden.\*\***

::::

:::{card}

- Demonstration der Schwachstellen

> **\*\*Bringen Sie (mind.) einen Rechner mit, auf dem Sie alle Tools etc. installiert haben, und mit**  
>

> Das Anlegen von (kleineren) Scripten ist ggf. empfohlen.

- Beantwortung von Fragen

**\*\*Jeder muss zu jeder Lücke sprechfähig sein.\*\***

- Notenanteil: 25% von der Gesamtnote - d. h. 30 Punkte:

- Dauer: ca. 25 Minuten pro Gruppe

:::

::::{card}

:::{rubric} Teilnahme am Pentest

:::

Laden Sie bis zum X.Y.2027 7:00 Uhr, Ihre Bestätigung der Teilnahmebedingungen hoch.

::::

# Gruppenzuteilung Pentesting

Datum: X.Y.2027

Ort: 261 C

| # | Uhrzeit | 1. Stud. | 2. Stud. | 3. Stud. |
|---|---------|----------|----------|----------|
| 1 | 8:30    | X        | Y        | Z        |
| 2 | 9:10    | X        | Y        | Z        |
| 3 | 9:50    | X        | Y        | Z        |
| 4 | 10:30   | X        | Y        | Z        |
| 5 | 11:10   | X        | Y        | Z        |
| 6 | 13:30   | X        | Y        | Z        |
| 7 | 14:10   | X        | Y        | Z        |
| 8 | 14:50   | X        | Y        | Z        |

# Pentesting

Die folgenden Server dürfen Sie einem Pentest unterziehen:

| Server                                                       | Komplexität |
|--------------------------------------------------------------|-------------|
| 141.72.13.218                                                | *           |
| 141.72.12.145                                                | **          |
| 141.72.12.138                                                | **          |
| <i>four-wins.michael-eichberg-at-dhbw-de.users.dhbw.site</i> | **          |
| 141.72.176.151                                               | * _ **      |
| <b>(ab 4. Juli)</b>                                          |             |
| 141.72.12.141                                                | ***         |
| <i>quizzzy.michael-eichberg-at-dhbw-de.users.dhbw.site</i>   |             |

## 🕒 Legende

\* = einfach; \*\*\* = sehr schwer

## ⚠ !GEFAHR!

Unter keinen Umständen dürfen Sie andere als die hier gelisteten Server *angreifen*. Scans von Subdomänen (es gibt auch keine) oder anderen IP-Adressen sind untersagt.

Sie dürfen auch immer nur die hier beschriebenen Angriffe/Änderungen vornehmen. Jegliche darüber hinausgehenden Tätigkeiten sind untersagt.

## ⌘ Hinweis

Pentesting der VMs ist nur aus dem Netz der DHBW heraus möglich. D. h. nur wenn Sie eine IP-Adresse im Bereich 141.72.0.0/16 haben. Nutzen Sie eine VM auf OpenStack, dann stellen Sie sicher, dass diese VM keine Egress-Filterung vornimmt und im richtigen Netz ist (ggf. in den Security-Policies zu konfigurieren). Wenn Sie sich per VPN verbinden, dann sollte dies immer der Fall sein.



# Pentesting - Rahmenbedingungen

## Was ist erlaubt/was nicht...

- Metasploit ist nicht zu verwenden, erfolgreiche Angriffe mit Metasploit werden nicht anerkannt.
- Horizontale Privilegienerweiterungen, sind nicht prüfungsrelevant.
- Alle Sicherheitslücken, die ggf. direkt auf die Verwendung von HTTP zurückzuführen sind, sind zu ignorieren!
- Sollten Sie ggf. auf Informationen über Nutzeraccounts stoßen oder selbige angreifen wollen, dann **nehmen Sie den Nutzeraccount/Gruppenaccount, der zu Ihrer Gruppennummer gehört.**
- Möchten Sie auf einem Server Daten ablegen, dann legen Sie diese auf jeden Fall **nur** in dem Verzeichnis ab, der zu Ihrer Gruppennummer passt! (/home/gruppe<N>, /home/group<N>, ...)
- Sollten Sie Zugriff auf einen Server bekommen - sei es als normaler Nutzer oder als Root-Nutzer - dann dürfen Sie sich auf jeden Fall frei umsehen.
- Die Server haben ggf. viele Schwachstellen; die aber bei Weitem nicht alle gleich einfach auszunutzen sind; suchen Sie die einfachste!
- Bei den Webanwendungen sollten Sie versuchen, so viele verschiedene Schwachstellen wie möglich zu finden. Mappen Sie Ihre Schwachstelle auch immer auf eine CWE! Schwachstellen, den immer nur dieselbe CWE zugrunde liegt, wird nur als eine Schwachstelle gewertet.
- Bei allen Aktionen bedenken Sie, dass auch andere Personen an dem Pentest teilnehmen und eine Einschränkung anderer Personen nicht gestattet ist.
- Sie dürfen keine Maßnahmen durchführen, die die Verfügbarkeiten der Server dramatisch einschränken.
- Sie dürfen unter keinen Umständen Veränderungen oder Aktualisierungen an den Servereinstellungen vornehmen, sollten Sie auf einem oder mehreren Servern Root-Access erlangen!
- Die Struktur von Datenbanken (**alter** . . .) darf nicht verändert werden; semantisch sinnvolle Datensätze, um zum Beispiel die Privilegien eines Nutzer zu erweitern, dürfen hinzugefügt werden (**update** . . .). Daten, die zur Anwendungslogik gehören, dürfen nicht gelöscht werden!
- Untersagt sind darüber hinaus sämtliche Handlungen, die ein verständiger Teilnehmer bei objektiver Betrachtung als nicht vom Zweck der Veranstaltung gedeckt erkennen muss — unabhängig davon, ob sie in diesen Bedingungen ausdrücklich aufgeführt sind. Die vorstehenden Verbote sind beispielhaft, nicht abschließend zu verstehen.

### ♦ Bemerkung

Sollten Sie auf Probleme stoßen, dann melden Sie sich bitte sowohl **bei Herrn Rutesic** als auch bei mir per Mail.

### ⚠ Warnung

Für eine Teilnahme an dem Pentest ist die Gegenzeichnung bis zum 3. Juli 2026 7:00 Uhr erforderlich und *persönlich* im Moodle hochzuladen.

Datum: \_\_\_\_\_

Unterschrift: \_\_\_\_\_